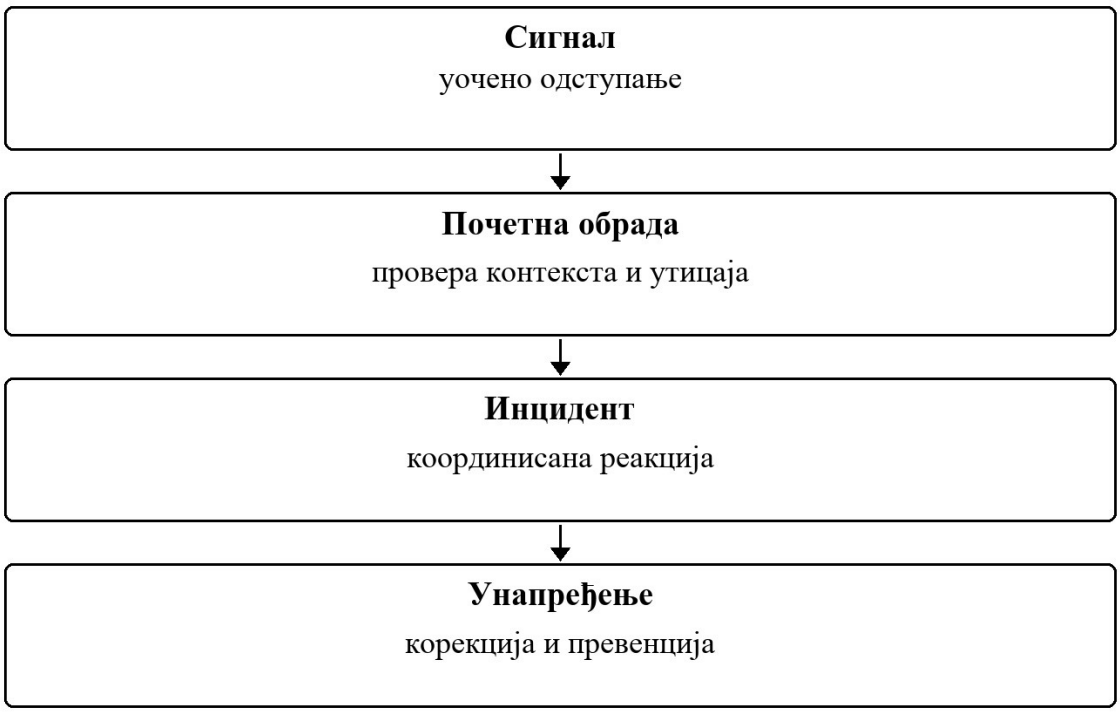
Детекција, инцидент и рањивости

Основе информационе безбедности · 06

Безбедносни догађај није аутоматски инцидент. Систем најпре препознаје сигнал, затим га ставља у контекст и тек онда одређује да ли је потребна реакција. Такав ток спречава и игнорисање проблема и непотребно алармирање због сваког одступања.

Управљање инцидентом даје структуру тренутку када је најлакше изгубити контекст. Рањивост постаје решив проблем када је повезана са имовином, приоритетом, власником и доказом да је корекција проверена.



Слика 1. Од сигнала ка проверљивој и смиреној реакцији

Безбедносна одлука настаје повезивањем приказаних појмова.

Циљ вежбе

Студент треба да образложи одлуку система, податке на којима се она заснива и њен утицај на заштиту података и услуга.

6.1 Сигнал тражи контекст

Управљање инцидентом даје структуру тренутку када је најлакше изгубити контекст. Рањивост постаје решив проблем када је повезана са имовином, приоритетом, власником и доказом да је корекција проверена.

- Праг детекције треба да има смисао и разлог, не само произвољну бројку.
- Затварање упозорења чува образложење, јер је то знање за следећи сличан случај.
- Рањивост није решена променом статуса, већ провером да је ризик заиста смањен.

Питање за дискусију

Који догађај би у вашем систему био користан сигнал, али не и довољан доказ инцидента? Који контекст недостаје?

6.2 Како се ова тема види у развоју

Тим бира мали број сигнала који су разумљиви оператеру. За сваки описује нормално понашање, разлог активирања, одговорну особу и безбедан начин провере. Тако се детекција дизајнира као производна могућност, а не као споредни лог.

Честе грешке које треба препознати

- Упозорење без власника и правила за почетну обраду.
- Аутоматско затварање без доказа о решавању узрока.
- Скенирање зависности без утврђеног начина процене и праћења налаза.

Веза са осталим темама

Разматрана одлука повезује идентитет, податке, политике и доказе, а исти поступак анализе примењује се на различите врсте информационих система.

6.3 Пример: више неуспелих пријава

Низ неуспелих пријава може указивати на заборављену лозинку, проблем интеграције или покушај злоупотребе. Сам број неуспеха није довољан за закључак. Почетна обрада укључује порекло покушаја, осетљивост налога и наставак обрасца након упозорења.

- Детекција описује образац који захтева проверу, без аутоматског проглашавања сваке грешке инцидентом.
- Почетна обрада бележи одлуку и разлог затварања упозорења.
- Затварање рањивости захтева доказ да је изложеност уклоњена или формално прихваћена као преостали ризик.

Критеријуми решења

Решење треба да буде образложено пословним контекстом, примењено на серверској страни и потврђено поновљивим тестом, ревизијским записом или демонстрацијом.

6.4 Дизајнерска одлука: сигнал није пресуда

Детекција покушава да примети промену понашања, не да аутоматски чита намеру корисника. Квалитетан сигнал зато наводи образац, праг и контекст који недостаје за коначну одлуку. Тиме оператер може брзо да разликује нормалан проблем рада система од потенцијалног безбедносног догађаја.

- Праг се бира према нормалном понашању система, а не према случајном броју.
- Упозорење има озбиљност, власника и рок до ког се мора погледати.
- Инцидент се отвара када контекст покаже стварни утицај или вероватну злоупотребу.

6.5 Учење након догађаја

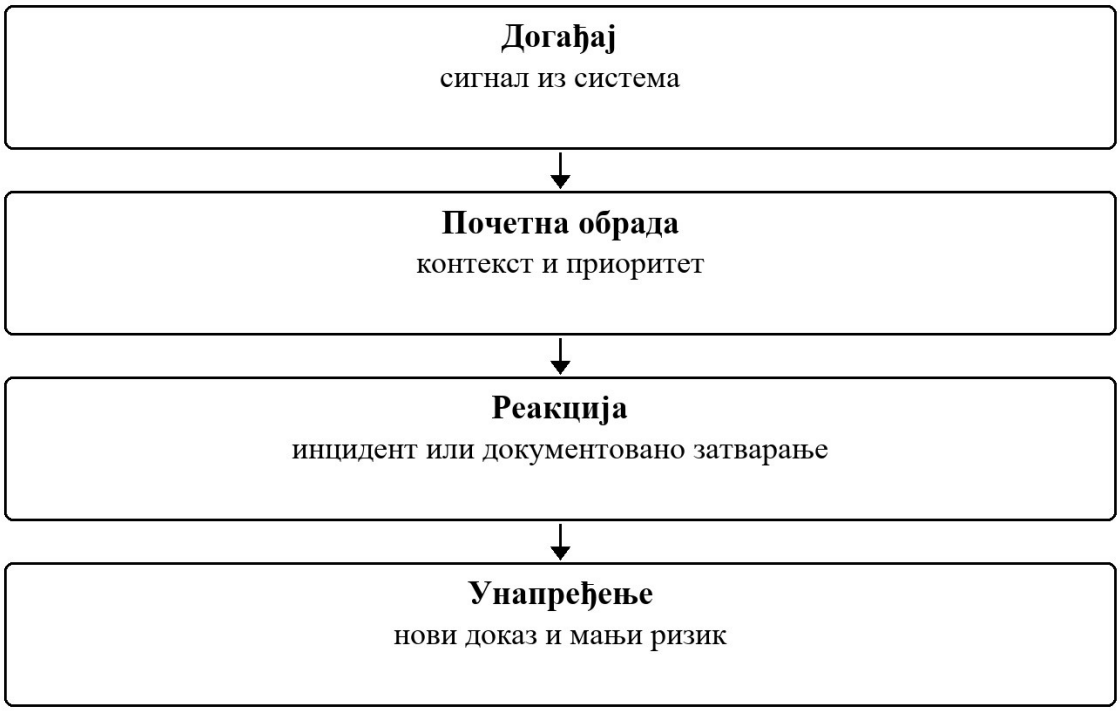
Добар пост-инцидент преглед није потрага за особом која је погрешила. Његов циљ је да пронађе где су недостајали сигнал, заштитна провера, јасна одговорност или припрема за опоравак. Резултат треба да мења систем или процес на начин који се може проверити.

- Хронологија одваја чињенице од претпоставки насталих под притиском.
- Акције након инцидента имају власника и проверљив завршетак.
- Нови сценарио се додаје у тестове или оперативне вежбе, како се исто знање не би изгубило.

Самостална провера

За изабрани сценарио наведите одлуку система, коришћене податке, очекивани исход и доказ на основу ког други члан тима може да потврди резултат.

6.6 Шема одговора на безбедносни догађај



Слика 2. Шема одговора на безбедносни догађај

Није сваки сигнал инцидент, али сваки значајан исход оставља знање корисно за следећу одлуку.

За сваки корак шеме одредите покретача, одлуку која се доноси и запис који остаје након извршења.

6.7 Сигнал, упозорење и инцидент

Табела 1. Стање и Шта представља

Стање	Шта представља	Потребна реакција
Сигнал	Сиров догађај или одступање.	Сачувати контекст и проверити правило.
Упозорење	Сигнал који је прешао дефинисан праг.	Почетна обрада и процена приоритета.
Инцидент	Потврђен или вероватан безбедносни утицај.	Координисана реакција и следљив ток.
Налаз рањивости	Потенцијална изложеност коју треба проценити.	Власник, рок и доказ корекције.

Тумачење поређења

Сваки појам описује посебан део безбедносне одлуке; тек њиховом правилном комбинацијом настаје целовит модел.

6.8 Ток управљања рањивошћу

Налаз постаје користан тек када се повеже са стварном имовином и њеном изложеношћу. Исти технички проблем нема исти приоритет на изолованом развојном рачунару и на јавно доступној услузи која обрађује осетљиве податке.

1. Потврдити да се налаз односи на конкретну компоненту и активну верзију.

2. Проценити утицај у контексту доступности, података и граница поверења.

3. Одредити корекцију, компензациону контролу или образложено прихватање ризика.

4. Затворити налаз тек када доказ потврди да је изложеност смањена.

Исход учења

Студент треба да уме да изабере одговарајућа питања за анализу безбедносно значајне одлуке и да образложи редослед њихове примене.

Примена на пројекту

На додељеној пројектној целини применити принцип из теме „Детекција, инцидент и рањивости". Идентификовати одлуку система, имплементирати је на серверској страни и припремити доказ у облику теста, ревизијског записа или демонстрације.

6.9 Извршиви пример

`RepeatedFailedLoginRule` препознаје најмање три неуспешне пријаве у десет минута. `IncidentFactory` из сигнала формира инцидент са одређеном озбиљношћу.

Пример 1. Покретање из репозиторијума наставног портала; потребан је дотнет 8 СДК.

```
cd examples/oib-dotnet/vezba-06-detekcija-incident
dotnet run --project src/Oib.Vezba06.ConsoleUi
dotnet test Oib.Vezba06.sln
```

Табела 2. Провера и Садржај

Провера	Садржај
Сценарио	Узастопни покушаји пријаве са исте адресе.
Тестови	`RepeatedFailedLoginRuleTests`, `IncidentFactoryTests`, `DetectIncidentsHandlerTests`
Доказ	`Incident` садржи идентификатор, озбиљност, сажетак и време отварања.

Задатак уз пример

Додати правило које препознаје пассворд спраиинг: иста адреса неуспешно покушава пријаву на више различитих налога. Написати нову `IDetectionRule` класу и регистровати је у корен композиције-у.